

Hands-on Lab: Using SNYK to scan your code repository

Estimated Time: 30 minutes

In this lab, you will become familiar with SNYK, pronounced as **Sneak**, to scan your code repository.

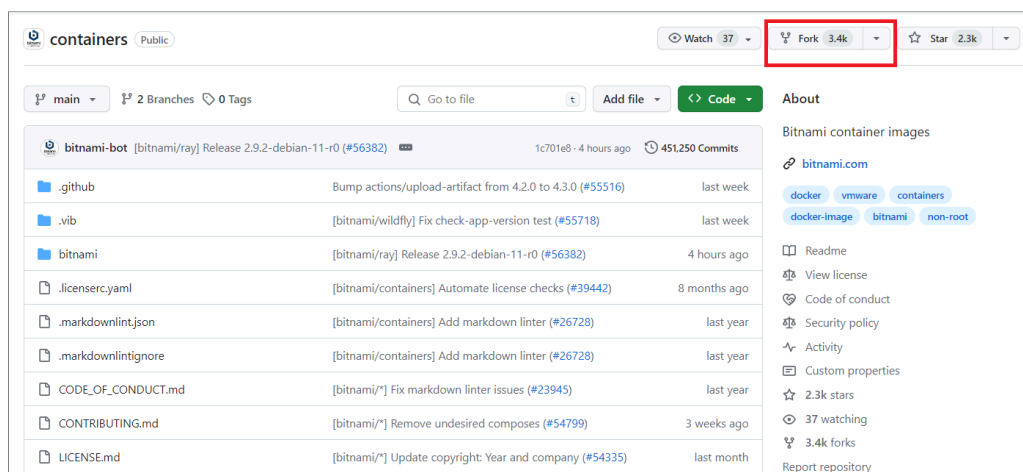
Learning Objectives:

After completing this exercise, you will be able to:

- Perform a scan of your code repository
- Analyze the code repository report

Pre-requisites

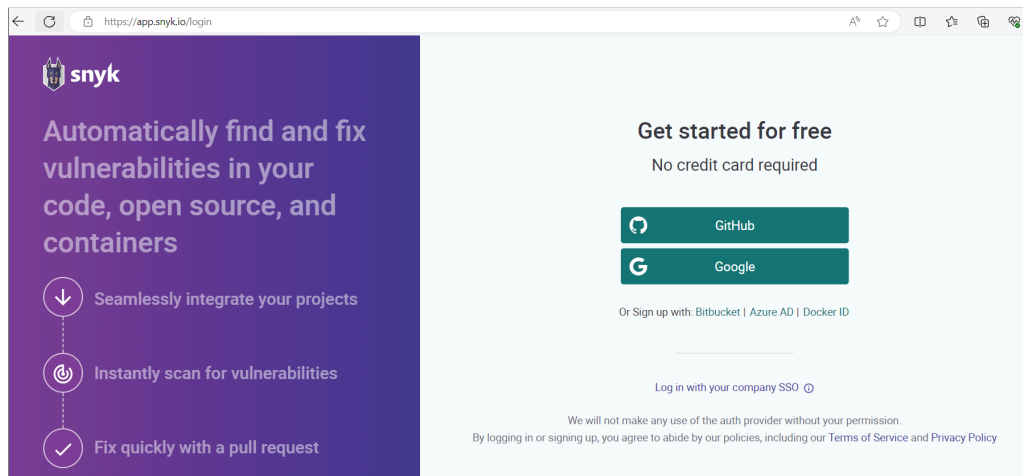
- You must have a GitHub account. If you don't have a GitHub account go to [this link](#), follow the instructions and sign-up.
- You should have some public and private repositories in your GitHub. If you don't have any, then let's create one. For example, if you want to create a copy of another public repository, <https://github.com/bitnami/containers>, go to the repository. Click **Fork** to fork the repository into your account. This will make a copy of the repository for you.



Adding a project to SNYK

SNYK software has many capabilities. But we will focus on the code repository vulnerability check which is offered as a free service.

1. Go to <https://app.snyk.io/login> and click login with GitHub.



2. If you are already logged into GitHub in your browser, go to next step. Otherwise, login with your Github credentials.





Sign in to **GitHub**
to continue to **Snyk Login**

Username or email address

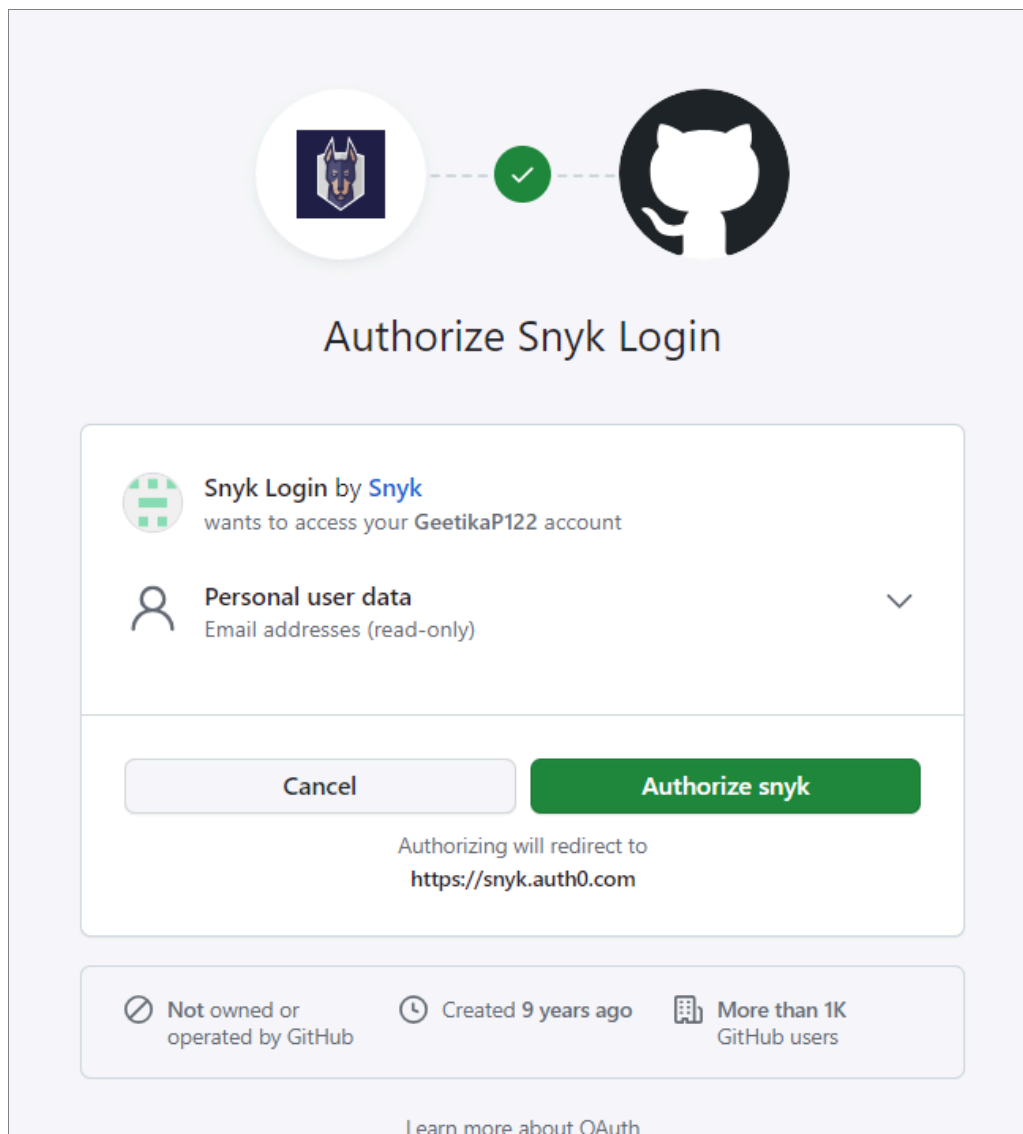
Password [Forgot password?](#)

Sign in

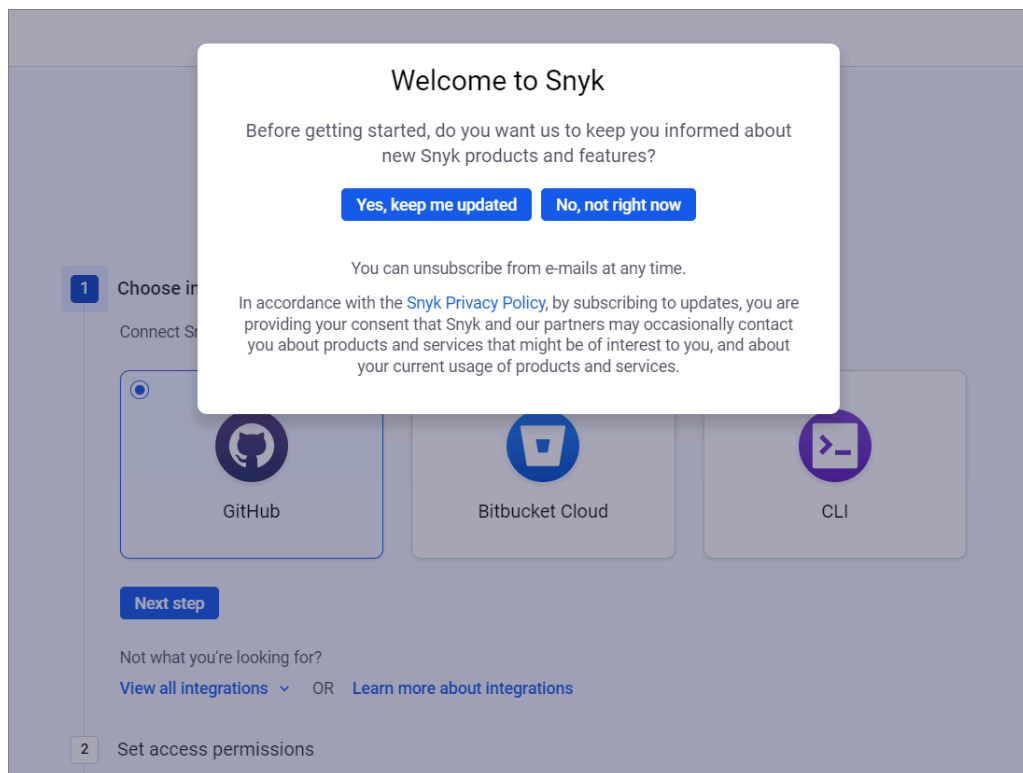
[Sign in with a passkey](#)

New to GitHub? [Create an account](#)

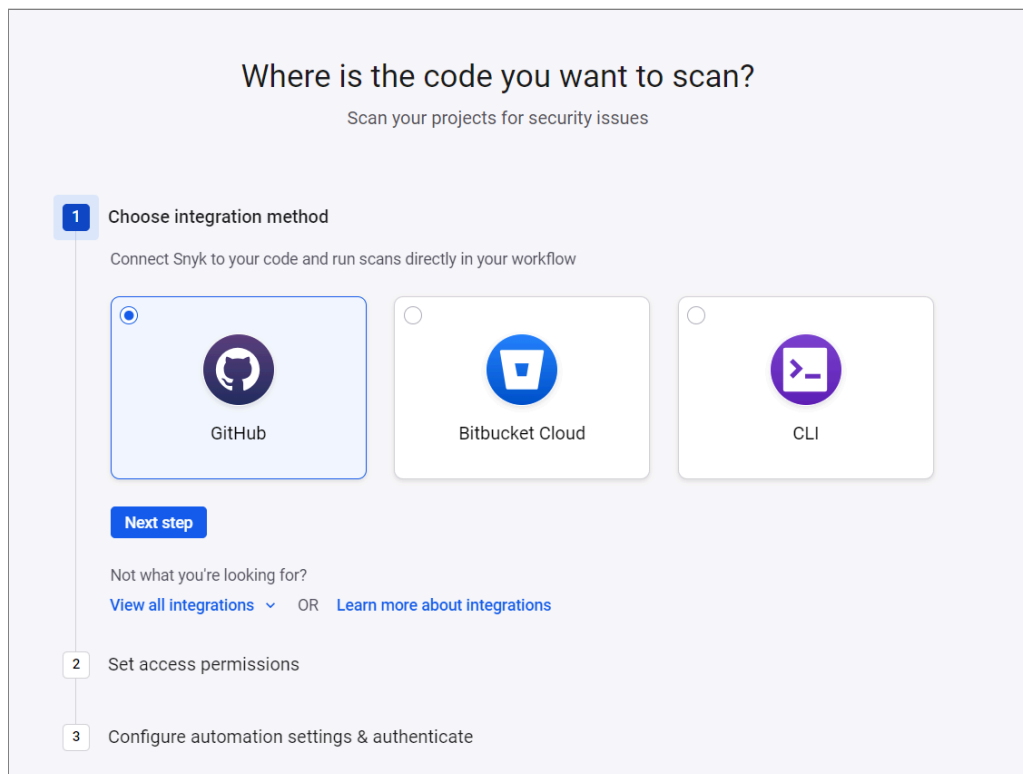
3. Provide permission and authorize snyk to use your GitHub credentials to login.



4. The first time you login, it asks if you want to subscribe for information on product releases and feature updates. Click **No, not right now**.



5. Choose the location of the code you want to test. For this exercise, choose Github. You are free to choose BitBucket if you have an account already.



6. You are presented with options to choose between using both public and private repositories (or repos) or just the public repos. Choose **Public repos only**.

Where is the code you want to scan?

Scan your projects for security issues

✓ Choose integration method

2

Set access permissions

3

Configure automation settings & authenticate

☐ Private and public repositories
Grant Snyk access to all repository types under your Github account whether private or public.

☒ Public repositories only
Grant Snyk access to repositories marked public under your Github account.

Once authenticated, Snyk:

- ✓ Scans the directory trees of selected repos and automatically represents them as projects
- ✓ Generates security reports that enable you to explore issues in your repositories and assist you with fixing them
- ✓ Continuously checks imported projects for vulnerabilities. When new vulnerabilities are found, you'll be notified

Next step

Previous

7. Check and select all the types of scans you would like snyk to do and click **Authenticate Github**.

✓ Choose integration method

✓ Set access permissions

3

Configure automation settings & authenticate

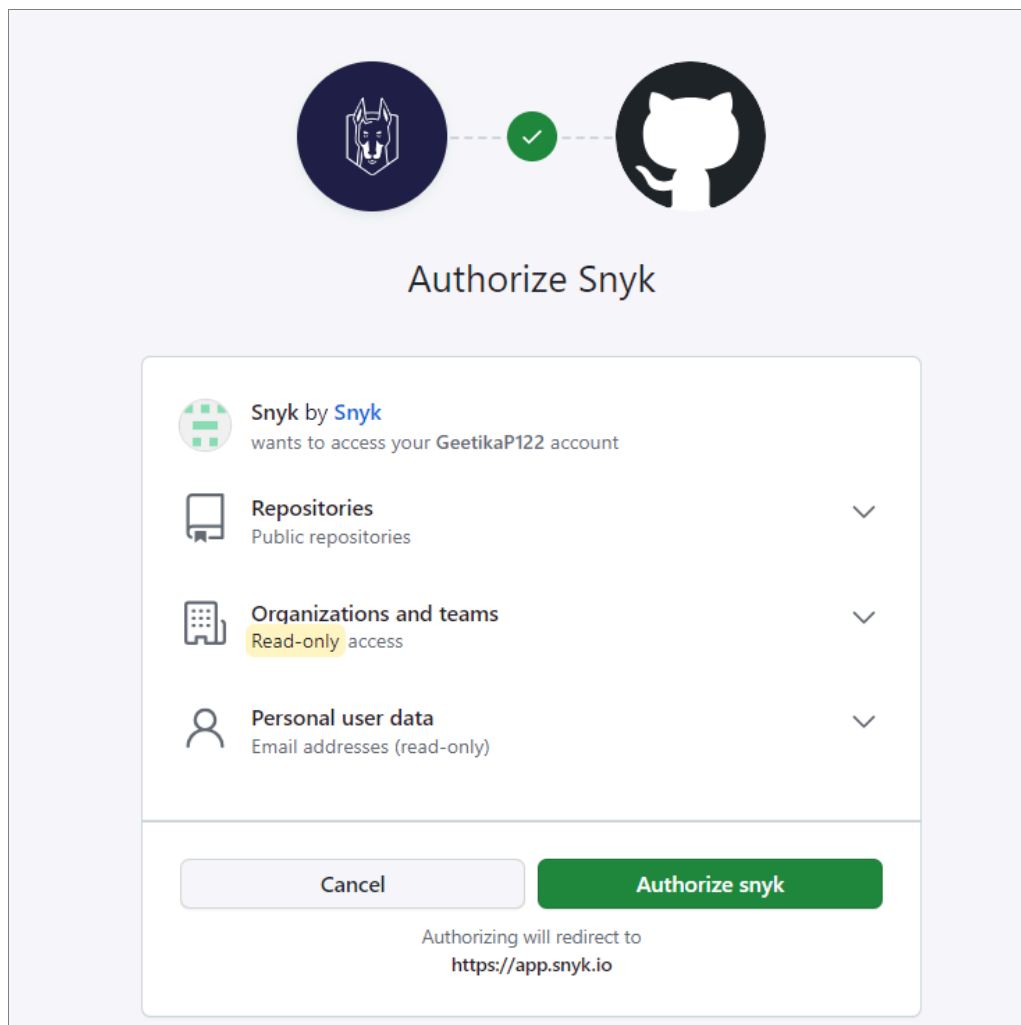
Enabled features:

- ☒ Pull Request Checks
Test your pull requests for new issues and vulnerabilities
- ☒ New Fix Pull Requests
Automatically create pull requests for newly discovered open source issues and vulnerabilities
- ☒ Dependency Upgrade Pull Requests
Keep your packages up to date with automatic dependency upgrade pull requests
- ☒ Snyk Code
Analyze your source code for issues and vulnerabilities ⓘ

Authenticate GitHub

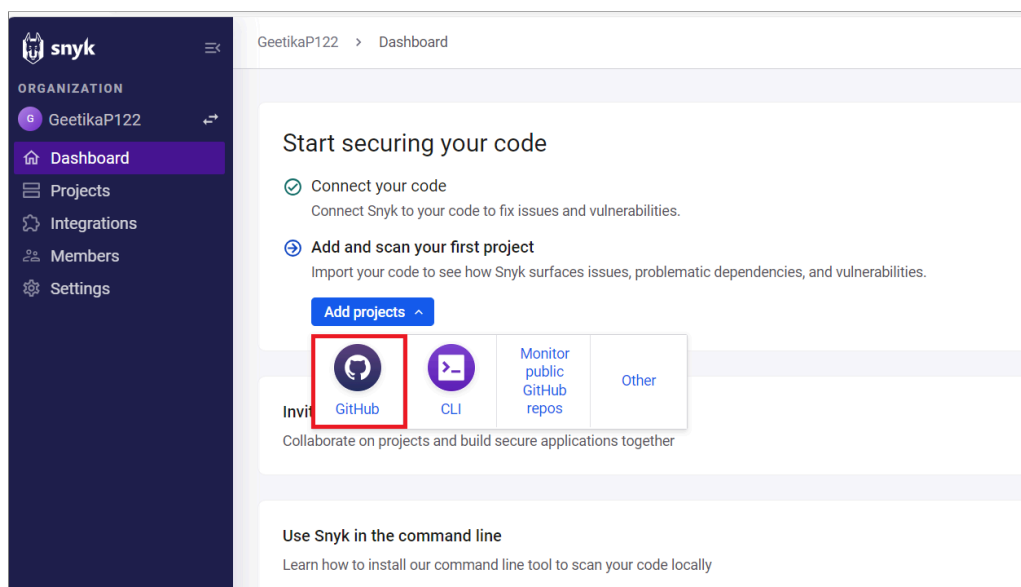
Previous

8. Github requires you to explicitly allow snyk to use your public repos. Click **Authorize snyk** to do so.



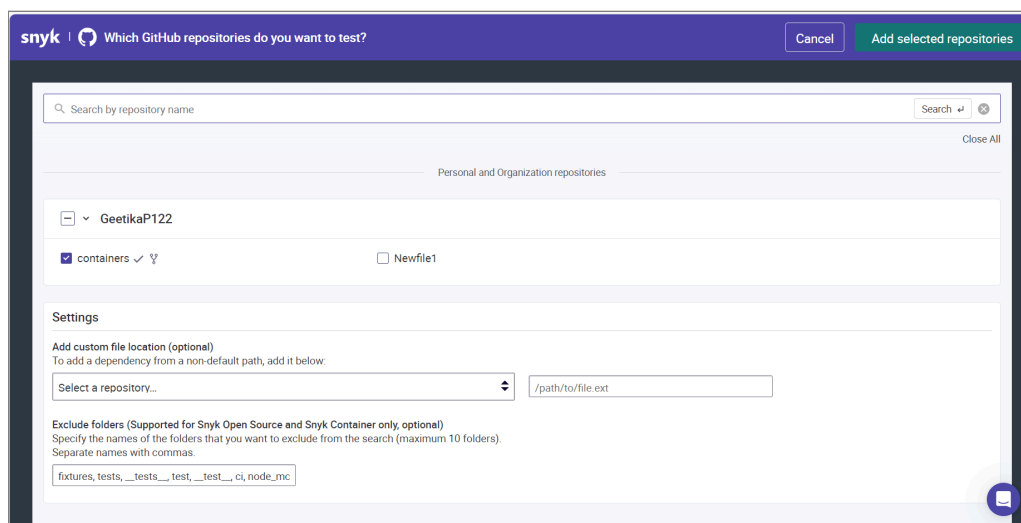
9. It takes you to the **Dashboard**, where you can click **Add Projects**. You have options to choose from.

- Github
- CLI
- Monitor public Github repos
- Other sources (BitBucket, Cloud, etc.,)



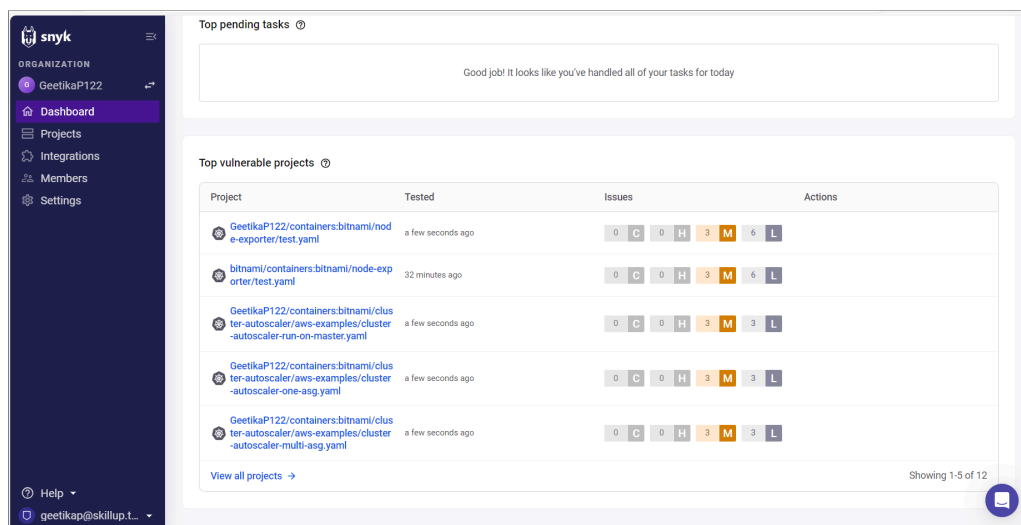
10. Click **Github** to see all your public repos listed. You can scan one of your public repos.

11. You can choose your repos and Add the selected repos to scan.

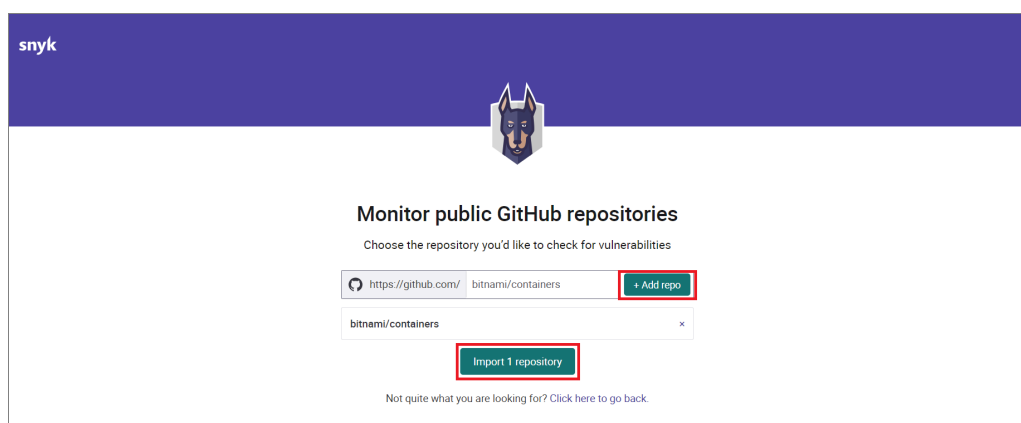


Depending on the size of your repo, scan might take time.

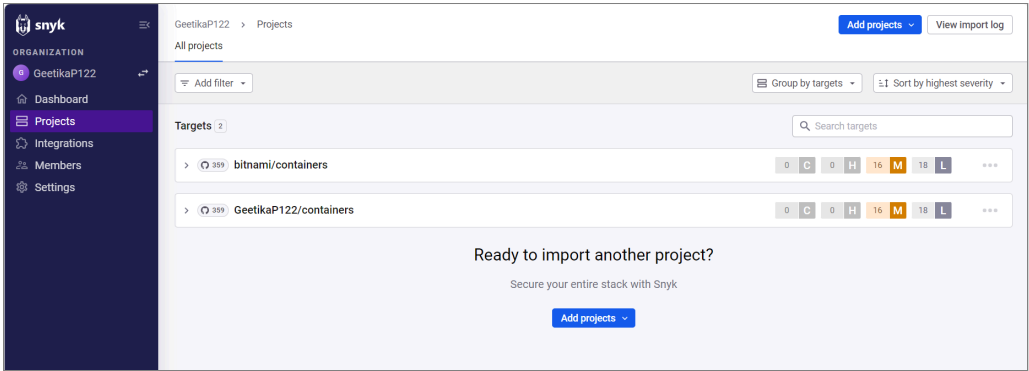
12. Click **Add Project** again and choose, **Monitor public Github repos** option.



13. Type the name of a public url. For example, the image below shows <https://github.com/bitnami/containers>. Click **Add repo** and then click **Import 1 repository**.



14. Once the repo is imported, the scanning begins for vulnerabilities. This takes a few seconds, after which a report is generated showing how many projects in the repository were scanned and how many **Critical**, **High** priority, **Medium** priority and **Low** priority vulnerabilities were found in these.



Congratulations! You just learned how to scan code with Snyk.

You may try to run this code scan on your own repos or other public GitHub repositories for practice.

Author(s)

Lavanya T S



Skills Network